

Checklist

Industry Compliance Standards and Frameworks

Core Compliance Concepts

- ☐ Understand that **compliance standards are minimum requirements**, not complete security programs.
- ☐ Know that an organization can be compliant and still have security weaknesses.
- ☐ Understand the difference between **regulatory compliance standards** and **security frameworks**.
- ☐ Remember that compliance requirements can vary by industry, country, and governing body.
- ☐ Recognize the role of compliance officers in coordinating regulatory requirements.
- ☐ Understand that compliance requirements may involve administrative, technical, and physical controls.

Industry Compliance Standards

FERPA — Family Educational Rights and Privacy Act

- ☐ Know that FERPA protects the privacy of **student education records**.
- ☐ Know that it applies to educational institutions, including higher education.
- ☐ Understand the distinction between **education records** and **directory information**.
- ☐ Know that personally identifiable information (PII) generally requires authorization before disclosure.
- ☐ Understand that consent should identify:
 - ☐ Information being disclosed
 - ☐ Reason for disclosure
 - ☐ Parties receiving the information

- ☐ Recognize examples of education records:
 - ☐ Transcripts
 - ☐ GPA
 - ☐ Grades
 - ☐ Social Security numbers
 - ☐ Academic evaluations
- ☐ Remember that FERPA contains relatively limited specific cybersecurity requirements.

GLBA — Gramm-Leach-Bliley Act

- ☐ Know that GLBA applies primarily to **financial institutions**.
- ☐ Understand that GLBA protects **nonpublic personal information (NPI)**.
- ☐ Know that financial institutions have an ongoing obligation to protect customer privacy and confidentiality.
- ☐ Understand that GLBA requires administrative, technical, and physical safeguards.
- ☐ Review important GLBA security controls:
 - ☐ Access controls
 - ☐ Audit trails
 - ☐ Change management
 - ☐ Disposal procedures
 - ☐ Encryption
 - ☐ Multi-factor authentication
 - ☐ Secure development practices
 - ☐ Protection of sensitive customer information
 - ☐ System inventory
 - ☐ System monitoring
 - ☐ Third-party standards and frameworks
 - ☐ Written risk assessments
- ☐ Understand that third-party service providers may also be required to comply.
- ☐ Know that enforcement may involve the FTC, FDIC, Federal Reserve, OCC, and other regulators.
- ☐ Recognize that violations can result in fines and remediation requirements.

HIPAA — Health Insurance Portability and Accountability Act

- ☐ Know that HIPAA protects **electronic protected health information (ePHI)**.
- ☐ Identify covered organizations:

- ☐ Healthcare providers
- ☐ Health plans
- ☐ Healthcare clearinghouses
- ☐ Know that HIPAA requirements are divided into:
 - ☐ Administrative safeguards
 - ☐ Physical safeguards
 - ☐ Technical safeguards
 - ☐ Policies and procedures
 - ☐ Documentation requirements
- ☐ Understand the difference between **required** and **addressable** implementation specifications.
- ☐ Know that organizations should perform a **risk assessment** and mitigate identified risks.
- ☐ Understand that HIPAA violations and breaches may need to be reported to HHS and, in some cases, the FTC.
- ☐ Recognize that HIPAA violations can result in civil and criminal penalties.

PCI DSS — Payment Card Industry Data Security Standard

- ☐ Know that PCI DSS protects **payment card and cardholder data**.
- ☐ Know that it applies to organizations that store, process, or transmit payment card information.
- ☐ Understand that PCI DSS is required by major payment card brands.
- ☐ Know that PCI DSS is administered by the **PCI Security Standards Council (PCI SSC)**.
- ☐ Identify cardholder data examples:
 - ☐ Primary account number (PAN)
 - ☐ Cardholder name
 - ☐ Expiration date
 - ☐ Service code
- ☐ Understand that PCI DSS is intended to reduce payment-card fraud and strengthen cardholder-data security.
- ☐ Recognize that failure to validate compliance can result in fines, penalties, or loss of card-processing capability.

SOX — Sarbanes-Oxley Act

- ☐ Know that SOX was enacted in **2002**.
- ☐ Understand that SOX focuses on corporate governance and financial reporting.

- ☐ Know that it applies primarily to U.S. public companies and public accounting firms.
- ☐ Understand the cybersecurity relevance of:
 - ☐ **Section 302**
 - ☐ **Section 404**
- ☐ Know that Section 302 requires safeguards to help ensure accurate financial reporting.
- ☐ Know that Section 404 requires controls to be independently verifiable by auditors.
- ☐ Understand that security-related weaknesses affecting financial information may need to be disclosed.
- ☐ Recognize that organizations commonly use **COSO** or **COBIT** to support SOX compliance.

Security Frameworks

CIS — Center for Internet Security

- ☐ Know that CIS provides cybersecurity benchmarks and system-hardening guidance.
- ☐ Recognize that CIS provides resources for securing operating systems and applications.
- ☐ Understand that CIS materials can complement NIST and other frameworks.

CCM — Cloud Controls Matrix

- ☐ Know that CCM is maintained by the **Cloud Security Alliance (CSA)**.
- ☐ Understand that CCM is designed specifically for **cloud security**.
- ☐ Know that it maps cloud security concerns and practices to major compliance standards.
- ☐ Understand that CCM controls are organized into multiple security domains.

COSO — Committee of Sponsoring Organizations of the Treadway Commission

- ☐ Know that COSO provides guidance related to:
 - ☐ Enterprise risk management
 - ☐ Internal controls
 - ☐ Fraud deterrence

- ☐ Recognize that COSO is commonly associated with SOX compliance.

COBIT — Control Objectives for Information and Related Technologies

- ☐ Know that COBIT was developed by **ISACA**.
- ☐ Understand that COBIT helps organizations with governance, documentation, implementation, and compliance.
- ☐ Know the major COBIT domains:
 - ☐ Plan and Organize
 - ☐ Acquire and Implement
 - ☐ Deliver and Support
 - ☐ Monitor and Evaluate
- ☐ Recognize that COBIT can align with more detailed security standards and frameworks.

ISO 27000 Series

- ☐ Know that the ISO 27000 series focuses on **information security management**.
- ☐ Know the purpose of major standards:
 - ☐ **ISO 27001** — Requirements for establishing, implementing, maintaining, and continually improving an ISMS.
 - ☐ **ISO 27002** — Information security management guidelines and principles.
 - ☐ **ISO 27003** — ISMS implementation guidance.
 - ☐ **ISO 27004** — Security measurement and assessment guidance.
 - ☐ **ISO 27005** — Information security risk management guidance.
 - ☐ **ISO 27006** — Requirements for organizations that audit and certify ISMSs.
- ☐ Understand the purpose of an **Information Security Management System (ISMS)**.

MITRE ATT&CK

- ☐ Know that MITRE ATT&CK documents common adversary:
 - ☐ Tactics
 - ☐ Techniques
 - ☐ Procedures
- ☐ Understand that it is used by both offensive and defensive security teams.
- ☐ Know that ATT&CK covers areas such as:

- ☐ Enterprise systems
- ☐ Cloud platforms
- ☐ Mobile devices
- ☐ Industrial control systems
- ☐ Understand that ATT&CK helps improve threat detection and defense capabilities.

NIST Cybersecurity Framework — NIST CSF

- ☐ Know that NIST is part of the **U.S. Department of Commerce**.
- ☐ Understand that the CSF provides guidance for managing cybersecurity risk.
- ☐ Know the three major CSF components discussed in the chapter:
 - ☐ Framework Core
 - ☐ Framework Profiles
 - ☐ Framework Implementation Tiers
- ☐ Understand that the Core describes cybersecurity activities and outcomes.
- ☐ Understand that Profiles help identify and prioritize cybersecurity improvements.
- ☐ Understand that Implementation Tiers provide context for how an organization manages cybersecurity risk.

Regulated Industries

Financial Sector

- ☐ Recognize that financial organizations process highly valuable financial and personal data.
- ☐ Identify common financial-sector risks:
 - ☐ Account takeover
 - ☐ Third-party payment processor breaches
 - ☐ ATM skimming
 - ☐ Point-of-sale vulnerabilities
 - ☐ Mobile banking attacks
 - ☐ Internet banking attacks
 - ☐ Supply-chain compromise
- ☐ Understand that legacy systems can increase security risk.

Government

- ☐ Understand that government agencies handle large amounts of highly sensitive information.
- ☐ Recognize challenges such as:
 - ☐ Slow approval processes
 - ☐ Legacy technology
 - ☐ Difficulty adopting new security controls
 - ☐ Complex regulations
- ☐ Know important U.S. government cybersecurity requirements and programs.

CMMC — Cybersecurity Maturity Model Certification

- ☐ Know that CMMC uses a tiered/maturity-based approach to cybersecurity.
- ☐ Understand its importance to organizations in the **defense supply chain**.
- ☐ Recognize its role in evaluating contractors and contractual cybersecurity requirements.

DoD Impact Levels

- ☐ Understand that DoD Impact Levels classify information based on sensitivity.
- ☐ Know that different levels require different security protections.
- ☐ Recognize their importance when selecting cloud service providers.

FedRAMP — Federal Risk and Authorization Management Program

- ☐ Know that FedRAMP provides security requirements for cloud services used by the federal government.
- ☐ Understand that FedRAMP is based in part on **NIST SP 800-53** controls.
- ☐ Recognize that cloud service providers must meet government-specific security controls.

FISMA — Federal Information Security Management Act

- ☐ Know that FISMA establishes federal information security requirements.
- ☐ Understand that it covers development, documentation, and implementation of information security programs.
- ☐ Recognize its influence on cybersecurity practices across government organizations.

Healthcare

- ☐ Understand that healthcare organizations store highly sensitive patient information.

- ☐ Recognize the risks created by outdated and legacy medical systems.
- ☐ Understand that medical-device patching and operating-system upgrades can present additional challenges.
- ☐ Know that HIPAA violations may result in:
 - ☐ Financial penalties
 - ☐ Criminal penalties
 - ☐ Required corrective actions
- ☐ Understand that healthcare breaches involving PHI can be particularly damaging.

HITRUST CSF

- ☐ Know that HITRUST CSF is widely used in the healthcare industry.
- ☐ Understand that it combines and harmonizes multiple standards and frameworks.
- ☐ Recognize examples incorporated into HITRUST:
 - ☐ HIPAA
 - ☐ NIST
 - ☐ ISO
 - ☐ PCI DSS

Final Review

- ☐ I can explain the difference between a **law/regulation**, a **compliance standard**, and a **security framework**.
- ☐ I can match FERPA, GLBA, HIPAA, PCI DSS, and SOX to the industries/data they protect.
- ☐ I can explain the purpose of CIS, CCM, COSO, COBIT, ISO 27000, MITRE ATT&CK, and NIST CSF.
- ☐ I can identify important government programs such as CMMC, FedRAMP, FISMA, and DoD Impact Levels.
- ☐ I can explain why the financial, government, and healthcare sectors are heavily regulated.
- ☐ I understand that **being compliant does not automatically mean being secure**.
- ☐ I understand that effective security combines compliance requirements with established frameworks and security best practices.

